

Security Lab

Governance, Risk & Compliance Summary



MITRE | ATT&CK®



AICPA®



Created By: Paul Leone
April 11, 2026

Table of Contents

Security Lab2

Governance, Risk & Compliance Summary2

 Executive Overview2

 Framework Alignment with Lab Mission2

 Architectural Principles Demonstrated.....2

 Multi-Cloud Hybrid Scope3

 Infrastructure Updates (v1.2 to v2.0)4

Framework Implementation Summaries5

 NIST Cybersecurity Framework 2.0.....5

 CIS Critical Security Controls v8.16

 ISO 27001:2022 Annex A7

 NIST SP 800-53 Rev 58

 MITRE ATT&CK Enterprise v18.19

 CISA Zero Trust Maturity Model v2.010

 NIST SP 800-207 Zero Trust Architecture11

 AICPA SOC 2 Trust Services Criteria (CC1-CC9).....12

Version History14

Security Lab

Governance, Risk & Compliance Summary

Document Control:

Field	Detail
Version	2.0
Last Updated	April 2026
Owner	Paul Leone
Framework Versions	NIST CSF 2.0, CIS Controls v8.1, ISO 27001:2022, NIST SP 800-53 Rev 5, MITRE ATT&CK Enterprise v18.1, CISA ZTMM v2.0, NIST SP 800-207, AICPA SOC 2 (TSC)



Executive Overview

Framework Alignment with Lab Mission

This cybersecurity lab demonstrates production-ready security capabilities aligned with eight industry frameworks, each validating distinct aspects of the lab mission: enterprise-grade SecOps, Systems Engineering, Network Defense, and multi-cloud hybrid operations.

Framework	Focus	Lab Score / Maturity
NIST CSF 2.0	Risk-based framework across 6 functions (Govern, Identify, Protect, Detect, Respond, Recover)	Tier 3-4 100% function coverage
CIS Controls v8.1	Prescriptive safeguards in 3 Implementation Groups	93% IG1 81% IG2 52% IG3
ISO 27001:2022	ISMS with 93 controls across 4 domains	77% overall 91% technological controls
NIST SP 800-53 Rev 5	Comprehensive control catalog across 20 families	100% AU 95% IA/SC/CM 90% AC/SI
MITRE ATT&CK v18.1	Adversary TTPs across 216 techniques / 475 sub-techniques	30% coverage (65/216 techniques)
CISA ZTMM v2.0	Four maturity stages across 5 pillars + 3 cross-cutting capabilities	Advanced (Stage 3/4)
NIST SP 800-207	Zero Trust Architecture tenets and logical components	Advanced All 7 tenets implemented
AICPA SOC 2	Trust Services Criteria (CC1-CC9): Security Common Criteria	Strong 30/33 criteria implemented

Architectural Principles Demonstrated

Every design decision maps to one of three core principles:

Defense in Depth

Validated across all eight frameworks. Overlapping controls span:

- Network perimeter: pfSense HA cluster, OPNsense, Palo Alto PA-VM NGFW (App-ID, Threat Prevention, User-ID), FortiGate 30D, Suricata/Snort IPS, SafeLine WAF
- Network visibility: Zeek NSM (protocol metadata, 3-segment coverage), ntopng/nProbe (NetFlow v9 from Cisco R1/R2/R3, 3560X, firewalls)
- Endpoint: Wazuh EDR across 31+ endpoints (25+ on-premises, 6 cloud), CIS Benchmark SCA (92-98% compliance)
- Identity: Authentik SSO, Active Directory, Palo Alto User-ID AD integration, Step-CA PKI

Secure by Design

Security embedded at the architecture level, not added after the fact:

- Mandatory encryption: TLS 1.3, AES-256, IPSec IKEv2 AES-256-GCM/SHA-384, GlobalProtect TLS 1.3
- Authenticated access: MFA (100% admin accounts), SSH key-based, certificate-based (Step-CA)
- Least privilege: Authentik RBAC, Palo Alto User-ID group-based policy, AD security groups
- IaC automation: Terraform, Ansible, Git version control with audit trails

Zero Trust Architecture

No implicit trust based on network location. Every request authenticated, authorized, and encrypted:

- Identity verification: MFA enforcement, Palo Alto User-ID AD mapping, Authentik SSO across 90%+ of services
- Network micro-segmentation: VLAN isolation, pfSense/OPNsense zone enforcement, Palo Alto security zones with default inter-zone deny
- Encrypted communications: TLS 1.3, IPSec IKEv2 site-to-site, GlobalProtect endpoint VPN, WireGuard (Tailscale)
- Assume-breach monitoring: Zeek protocol metadata, ntopng flow analysis, dual SIEM, 100% event logging

Multi-Cloud Hybrid Scope

Version 2.0 extends coverage to 6 cloud nodes across three providers, all connected via Tailscale WireGuard mesh VPN with no public management port exposure.

Provider	Nodes	OS	Native Security Services
----------	-------	----	--------------------------

AWS (us-east-2)	2	Amazon Linux 2, Windows Server 2025	GuardDuty, Security Hub, CloudTrail, VPC Flow Logs
Azure (North Central US)	2	Ubuntu 24.04 LTS, Windows Server 2025	Defender for Cloud, Sentinel, Entra ID, DDoS Protection
GCP (us-central1)	2	Debian 13.4, Ubuntu	Security Command Center, Cloud Armor, VPC Firewall Policy, Cloud Logging

All cloud nodes are enrolled in the on-premises management stack: Wazuh EDR, PatchMon (Linux), WSUS (Windows), Checkmk, Ansible, and Uptime Kuma. DNS resolves via on-premises Unbound (192.168.1.153/154) over Tailscale, inheriting DNSSEC validation and malware domain blocking.

Infrastructure Updates (v1.2 to v2.0)

Update	Components	GRC Impact
Palo Alto PA-VM NGFW	PAN-OS, App-ID, Threat Prevention, User-ID/AD, IPSec IKEv2, GlobalProtect VPN, security zone architecture	Advances PR (Protect), AC-17, SC-7/8, IA-2, CISA Networks/Identity, MITRE T1133/T1190
NSM Sensor: Zeek	3-worker AF_PACKET cluster; DNS/HTTP/SSL/SSH/SMB/RDP/DCE-RPC analyzers; Notice/Intel/Weird frameworks; JSON to Elastic + Brim/ZUI	Closes CISA Visibility gap; advances DE.CM-01, SI-4, CIS 13.1/13.2; improves T1046 coverage
NSM Sensor: ntopng/nProbe	Dual nProbe (Cisco flows UDP/2055, FW flows UDP/2056); ntopng web UI port 3000; local networks 192.168.3/100/200.0/24	Completes CIS 13.6 NetFlow; advances SI-4, AU-12, DE.CM-01
Multi-Cloud (AWS/Azure/GCP)	6 nodes via Tailscale WireGuard; Wazuh, PatchMon, Checkmk, Ansible across all providers; cloud-native security services	Extends all 8 frameworks to hybrid cloud scope; adds SA-9, SR-3, CM-8, A.5.23 cloud coverage
AICPA SOC 2 Added	CC1-CC9 Trust Services Criteria (Security Common Criteria)	New framework: 30/33 criteria implemented; strong CC5-CC8 coverage
Cisco/VLAN Enhancements	OSPF MD5 auth; 3560X DHCP snooping VLANs 10/20/30/100/120/200; uRPF on R3; R2 NetFlow added	Strengthens SC-7, CIS 12.1/12.2, PR.IR-01, network segmentation evidence

Framework Implementation Summaries

NIST Cybersecurity Framework 2.0

Overall Maturity: Tier 3 (Repeatable),
approaching Tier 4 (Adaptive)



Function	Tier	Key Implementation	Cloud Extension
GOVERN (GV)	Tier 3	CVSS-based risk prioritization; SLAs: Critical <72h, High <7d; policies version-controlled in Git; PAN-OS update lifecycle in supply chain controls	Cloud policies: no public management ports, Tailscale-only access, CIS SCA via Wazuh, IAM least-privilege per provider
IDENTIFY (ID)	Tier 4	Automated asset discovery: 30+ hosts, 5,000+ packages (PatchMon), 50+ containers (WUD); MITRE ATT&CK mapping; MISP threat intelligence	8 cloud nodes tracked in Checkmk, Wazuh, PatchMon; cloud VPC/VNet topology documented; CloudTrail/GCP Audit/Azure Monitor for asset lifecycle
PROTECT (PR)	Tier 4	Authentik SSO/MFA; TLS 1.3/AES-256; PA-VM App-ID/User-ID/IPSec/GlobalProtect; Step-CA PKI; IaC (Terraform/Ansible); CIS Benchmark audits	Wazuh CIS SCA on all 6 cloud nodes; PatchMon/WSUS patch management; Ansible hardening via Tailscale; no public ports
DETECT (DE)	Tier 3	100% network visibility; Zeek NSM (protocol metadata, 3 segments); ntopng/nProbe (NetFlow); PA-VM Threat Prevention; dual SIEM <5min MTTD	GuardDuty ML-based detection; GCP SCC asset/vulnerability/IDS; Azure Sentinel KQL rules (NSG spikes, geo sign-in anomalies, AMA gaps)
RESPOND (RS)	Tier 3	15+ TheHive playbooks; Shuffle SOAR; Cortex analysis; Wazuh Active Response; Zeek forensic metadata; PA-VM EDL for rapid IOC blocking	Wazuh Active Response on cloud nodes via Tailscale; GuardDuty/Sentinel auto-create TheHive cases via Shuffle
RECOVER (RC)	Tier 3	AES-256 encrypted backups (bi-weekly PBS); snapshot rollback; HA DNS failover <5s; IaC rebuild <2hr RTO; documented RTO/RPO	Cloud node rebuild via Ansible; RTO <2hr validated; Azure Spot eviction/restart documented; Uptime Kuma tunnel health monitoring

Key achievements: Full 6-function coverage; multi-SIEM (Splunk + Elastic + Wazuh) <5min MTTD; Shuffle SOAR 70% MTTR reduction vs. manual; NSM deployment closes network visibility gap; cloud integration strengthens IDENTIFY, PROTECT, and DETECT functions.

CIS Critical Security Controls v8.1

Overall: 93% IG1 / 81% IG2 / 52% IG3. 159 safeguards mapped across 18 control families.



IG Level	Status	Notes
IG1 (56 safeguards)	93% Compliant (52/56)	Complete coverage of asset inventory, data protection, patch management, centralized logging, malware defenses, backup/recovery. Minor gaps: application allowlisting (2.5), data flow diagrams (3.8)
IG2 (74 additional)	81% Compliant (60/74)	Advanced monitoring exceeds requirements. Palo Alto App-ID/Threat Prevention advance Controls 12 and 13. Gaps: network AAA (12.5), application allowlisting (2.5-2.7), pen testing (18.1-18.2)
IG3 (29 additional)	52% Compliant (15/29)	Host-based IPS (Wazuh Active Response), network IPS (Suricata inline + PA Threat Prevention), WAF (Safelane). Gaps: 802.1X NAC (13.9), DLP (3.13), mobile containerization (4.12), SAST/DAST (16.12)

Control	Score	Notes
1: Asset Inventory	99%	Cloud inventory integrated: 6 nodes (AWS, Azure, GCP) in Checkmk, Wazuh, PatchMon, Tailscale admin console
2: Software Inventory	70%	Allowlisting gaps remain. PatchMon extended to cloud nodes.
3: Data Protection	95%	IG1/IG2 complete. Cloud encryption: AWS S3 SSE, GCP disk/GCS, Azure Managed Disk + Log Analytics.
4: Secure Configuration	75%	PA-VM baseline added. Formal policy documentation needed.
5: Account Management	100%	Cloud IAM accounts integrated into lifecycle management.
6: Access Control	90%	Palo Alto User-ID strengthens identity-based access. RBAC documentation still needed.
7: Vulnerability Management	100%	Exceeds all baselines. Cloud scanning via Wazuh SCA, Inspector, SCC, Defender for Cloud.
8: Audit Log Management	98%	Zeek JSON and ntopng flow data added as log sources. Cloud audit logs integrated.
9: Email/Web Protection	65%	Limited by homelab scope; DNS filtering extended to cloud nodes.

10: Malware Defenses	100%	ClamAV on Linux cloud nodes; Defender on Windows cloud nodes; GuardDuty/SCC/Defender behavioral detection.
11: Data Recovery	100%	Cloud node recovery runbooks documented and tested; RTO <2hr.
12: Network Infrastructure	88%	PA-VM zone architecture + IPSec/GlobalProtect improve 12.2/12.3/12.7. Lacks AAA (12.5).
13: Network Monitoring	93%	Zeek (13.1/13.2) + ntopng/nProbe (13.6) + PA-VM Threat Prevention (13.8). R2 NetFlow gap closed. Lacks 802.1X (13.9).
16: Application Security	60%	Infrastructure focus; custom dev minimal. SBOM planned Q2 2026.
17: Incident Response	85%	Shuffle SOAR + TheHive playbooks. Cloud node IR runbooks documented.
18: Penetration Testing	40%	Vulnerability scanning substitute; formal testing not conducted.

ISO 27001:2022 Annex A

Overall: 77% coverage (55 implemented, 14 partial, 2 not implemented, 22 N/A). Applicable control coverage: 69/71.



International
Organization for
Standardization

Domain	Coverage	Key Highlights
5. Organizational Controls (37 total)	71% (22/31 implemented)	Threat intel (MISP/CrowdSec/GuardDuty/SCC/Sentinel); asset inventory 5,000+ packages; TLS 1.3 transfer (A.5.14); Authentik SSO (A.5.15); TheHive/Shuffle IR (A.5.24-28); Cloud IaaS security (A.5.23)
6. People Controls (8 total)	100% (2/2 applicable)	Remote working (A.6.7): Tailscale, GlobalProtect, MFA, TLS 1.3; security event reporting (A.6.8): Discord/email/TheHive + cloud-native alerting (SNS, GCP alerts, Azure Monitor)
7. Physical Controls (14 total)	33% (2/4 applicable)	Residential homelab constraints. Cloud physical security delegated to provider (AWS/GCP/Azure SOC 2/ISO 27001 data centers). Encrypted storage, DBAN disposal, UPS.
8. Technological Controls (34 total)	91% (29/32 applicable)	Wazuh EDR 31+ endpoints; MFA 100% admin; multi-engine malware defense; weekly

OpenVAS + monthly Nessus; PA-VM Threat Prevention (A.8.7/A.8.20); Zeek/ntopng NSM (A.8.16/A.8.20)

Key strengths: Technological excellence at 91% with enterprise-grade NSM and NGFW; incident response maturity with 15+ playbooks and SOAR orchestration; encryption everywhere (TLS 1.3, IPsec IKEv2, AES-256-GCM, ECDSA P-256, Ed25519, DNSSEC); high availability (HA firewall, dual DNS, dual SIEM). Remaining gaps: formal DLP (A.8.12, Q2 2026), information labeling (A.5.13).

NIST SP 800-53 Rev 5

324+ requirements across 18 families. High maturity in technical families; moderate in administrative families constrained by single-user lab scope.



Family	Score	Key Notes
Access Control (AC)	90%	27/30 implemented. Authentik SSO/MFA, AD RBAC, session management. Palo Alto User-ID (AC-3); GlobalProtect + IPsec VPN (AC-17).
Audit & Accountability (AU)	100%	18/18 implemented. Dual SIEM, 100% event coverage, 90-day hot/1-year cold. Zeek JSON + ntopng flow records as AU-12 sources.
Assessment & Auth (CA)	80%	8/10 implemented. Weekly OpenVAS + monthly Nessus. Cloud: GuardDuty, SCC, Defender for Cloud as CA-7 continuous monitoring.
Configuration Mgmt (CM)	95%	15/16 implemented. Ansible/Terraform IaC, Git, CIS baselines, 5,000+ package inventory. PA-VM config via Ansible, cloud IaC in Git.
Contingency Planning (CP)	75%	6/8 implemented. PBS bi-weekly encrypted backups, quarterly restore testing, HA DNS, <2hr IaC RTO. Cloud rebuild validated.
Identification & Auth (IA)	95%	17/18 implemented. Step-CA two-tier PKI, Ed25519 SSH, Authentik OIDC, Vaultwarden, MFA. PA-VM admin via AD; GlobalProtect pre-logon cert.
Incident Response (IR)	90%	11/13 implemented. TheHive 15+ playbooks, Shuffle SOAR, Cortex, Wazuh Active Response on all 31+ endpoints including cloud.
Maintenance (MA)	60%	4/6 implemented. SSH remote maintenance logged, Git change control, WSUS approvals. Formal MA documentation informal.
Risk Assessment (RA)	85%	10/12 implemented. CVSS scoring, daily PatchMon, weekly OpenVAS, monthly Nessus, 75+ assets. Cloud: Inspector, SCC, Defender for Cloud.

System & Comm Protection (SC)	95%	24/25 implemented. TLS 1.3, Ed25519, AES-256-GCM, Step-CA PKI. SC-7 includes PA-VM App-ID L7 + Threat Prevention IPS. IPSec IKEv2 + cloud boundary protection.
System & Info Integrity (SI)	90%	25/28 implemented. Wazuh FIM/EDR, Suricata/Snort/PA-VM IPS, ClamAV/Defender, automated patching. NSM host (192.168.1.48) adds SI-4 network telemetry.
Supply Chain (SR)	40%	4/12 implemented. Vetted open-source, Docker SHA-256, secure deletion. Cloud: IAM least-privilege, minimal service accounts, ARM securestring params.

MITRE ATT&CK Enterprise v18.1

Framework version: v18.1

(October 2025). **Total**

techniques: 216. **Total sub-**

techniques: 475. **Lab coverage:**

30% (65/216 techniques across 12 tactics).

Coverage decreased from 34% to 30% due to v18.1 adding 25 new techniques (13% denominator growth). T1537 upgraded MINIMAL to PARTIAL with cloud storage monitoring additions



Tactic	Coverage	Maturity	Key Detections
Initial Access (TA0001)	67% (6/9)	Strong	Auth anomalies, VPN logging, WAF blocking, phishing workflow (Cortex + MISP), USB monitoring
Execution (TA0002)	67% (9/13)	Strong	Sysmon process creation, PowerShell script block logging, scheduled task monitoring, LOLBin detection
Persistence (TA0003)	37% (8/20)	Moderate	AD group changes (4728/4732/4756), Wazuh FIM startup/systemd, service creation monitoring
Privilege Escalation (TA0004)	38% (5/13)	Moderate	Admin logon correlation, GPO modification auditing (5136/5137/5141), sudo tracking
Defense Evasion (TA0005)	21% (13/46)	Weak	Immutable SIEM logs, registry tracking, security tool tamper detection, cloud security tool monitoring
Credential Access (TA0006)	28% (4/15)	Weak	Brute force multi-source detection, LSASS monitoring (Sysmon EID 10), Kerberos partial (EID 4768/4769)
Discovery (TA0007)	32% (10/32)	Moderate	Suricata port scan/sweep/ARP; Zeek conn.log + ntopng improve T1046; AD LDAP auditing (4662)
Lateral Movement (TA0008)	56% (5/9)	Strong	RDP (Suricata + EID 4624 type 10), SMB (5140/5145), SSH; Zeek rdp/smb/ssh logs for correlation
Collection (TA0009)	20% (4/18)	Weak	Archive detection, USB insertion (EID 2003), Wazuh FIM sensitive dirs. No DLP.

Exfiltration (TA0010)	46% (4/9)	Moderate	C2 channel monitoring, MISP IOC, Zeek DNS/ntopng outbound; T1537 partial via cloud audit logs
Command & Control (TA0011)	42% (6/16)	Moderate	Suricata HTTP/HTTPS/DNS/SMTP, Unbound DGA detection, Zeek analyzers, PA-VM App-ID tunneling blocks
Impact (TA0040)	46% (6/13)	Moderate	Ransomware: Wazuh mass file modification + Shuffle workflow; cryptomining; Prometheus CPU/process detection

v18.1 critical new techniques requiring implementation: T1059.013 (Container CLI/API), T1678 (Delay Execution), T1679 (Selective Exclusion), T1036.012 (Browser Fingerprint Masquerading), T1562.013 (Network Device Firewall), T1546.018 (Python Startup Hooks), T1213.006 (Database Exfiltration).

CISA Zero Trust Maturity Model v2.0

Overall: Advanced (Stage 3/4). 87% of functions at Advanced or higher. Hybrid deployment combining device agent/gateway (Authentik + Traefik), enclave gateway (pfSense/OPNsense/PA-VM), and resource portal (Traefik) approaches



America's Cyber Defense Agency
NATIONAL COORDINATOR FOR CRITICAL INFRASTRUCTURE SECURITY AND RESILIENCE

Pillar	Maturity	Evidence Summary	Next Steps
Identity	Advanced	Authentik SSO 100%, TOTP MFA all admin, SSH cert auth (Step-CA), Palo Alto User-ID AD group policy, 30-min session timeouts, quarterly access reviews	WebAuthn/FIDO2 deployment; Authentik-to-PA-VM SAML integration
Devices	Advanced	Wazuh CIS SCA 92-98% compliance (31+ endpoints incl. 6 cloud); PatchMon 5,000+ packages; non-compliant devices quarantine VLAN; GlobalProtect pre-logon cert	MDM/device posture; SBOM tracking; Trivy/Grype Q2 2026; HIP enforcement
Networks	Advanced	VLAN + PA-VM zone segmentation (3-tier); pfSense CARP <5s failover; TLS 1.3; Step-CA 90-day cert rotation; cloud: Tailscale ACL default-deny, GCP Threat Intel blocking, Cloud Armor WAF/DDoS	Software-defined perimeter; dynamic just-in-time connectivity; mTLS for service-to-service
Applications & Workloads	Advanced	Authentik contextual auth (identity, device, IP, time, MFA); SafeLine WAF OWASP CRS 25% block rate; Traefik security headers; immutable	Service mesh (Istio); runtime protection; CI/CD security scanning Q2 2026

		containers; GCP Cloud Armor app-layer WAF	
Data	Advanced	Encryption everywhere (AES-256/TLS 1.3/IPSec/WireGuard); dual SIEM 90-day hot/1-year cold; cloud: AWS S3 SSE, GCP disk encryption, Azure Managed Disk + Log Analytics encrypted	Formal DLP Q2 2026; data tagging; encryption-in-use
Visibility & Analytics	Advanced	100% event logging; dual SIEM; Zeek NSM; ntopng flow dashboards; Grafana 20+ dashboards; cloud: GuardDuty/SCC/Sentinel behavioral analytics	ML/UEBA platform; PA-VM NetFlow/IPFIX integration
Automation & Orchestration	Advanced	Shuffle SOAR 15+ playbooks; Wazuh Active Response <30min MTTR; Terraform/Ansible IaC; Step-CA cert automation; cloud node Active Response via Tailscale	Predictive analytics; automated cloud network isolation
Governance	Advanced	Version-controlled policies (Git); Wazuh SCA 92-98% CIS; Critical <72h/High <7d MTTR SLAs; quarterly reviews; cloud: Security Hub, SCC, Defender Secure Score	Automated policy generation from threat intelligence

NIST SP 800-207 Zero Trust Architecture

Overall: Advanced maturity across all 7 ZT tenets. Deployment model: hybrid device agent/gateway (Authentik + Traefik), enclave gateway (pfSense/OPNsense/PA-VM/FortiGate), and resource portal (Traefik). Trust algorithm: hybrid score-based and criteria-based with contextual evaluation.



Tenet	Status	Implementation Evidence
1. All resources explicitly defined	Advanced	25+ hosts, 50+ containers, 30+ VMs; PA-VM, NSM, Zeek cluster, nProbe instances in inventory; 8 cloud nodes tracked
2. Communication secured regardless of location	Advanced	TLS 1.3 mandatory; IPSec IKEv2 AES-256-GCM site-to-site; GlobalProtect TLS 1.3; WireGuard (Tailscale); no implicit trust by network location
3. Per-session least privilege access	Advanced	30-min session timeouts; OAuth2 scopes; temporary sudo; session-based authorization; PA-VM User-ID per-session group policy

4. Dynamic policy from observable state	Advanced	Device compliance + AD identity (User-ID) + behavior + threat intel inform access decisions; Authentik evaluates 6+ contextual factors
5. Asset integrity monitoring	Advanced	Wazuh CIS compliance 92-98%; Nessus scans; PatchMon 5,000+ packages; drift detection; Zeek file hashing; all 6 cloud nodes in scope
6. Dynamic authentication/authorization	Advanced	MFA enforcement; continuous session evaluation; threat-triggered re-auth; PA-VM User-ID real-time AD mapping; cloud IAM scoped per provider
7. Comprehensive telemetry collection	Advanced	Dual SIEM 100% event logging; Zeek protocol metadata (3 segments); ntopng/nProbe flow data (5 infrastructure sources); cloud: CloudTrail, GCP Audit, Azure Monitor, Wazuh agent telemetry

Logical component deployment: Policy Engine (Authentik + PA-VM User-ID), Policy Administrator (Authentik OAuth2 token management + Traefik middleware), Policy Enforcement Point (multi-layer: Traefik ForwardAuth, pfSense/OPNsense/PA-VM firewalls, Safelane WAF, SSH cert validation, VLAN isolation).

AICPA SOC 2 Trust Services Criteria (CC1-CC9)

Framework: Trust Services Criteria (Security / Common Criteria). Scope: on-premises homelab + hybrid cloud (AWS, Azure, GCP, 6 nodes). Overall: Strong (30/33 criteria implemented).



Context: SOC 2 is designed for service organizations handling customer data. This mapping demonstrates control design and implementation capability aligned to the TSC criteria. It is not equivalent to a formal Type I or Type II attestation.

Category	Criteria	Assessment	Key Evidence
CC1: Control Environment	CC1.1-CC1.5	Partial	Security-first policies in Git; quarterly GRC reviews; RBAC via Authentik/AD; dual SIEM immutable audit trails; Git commit attribution. Organizational governance structures limited by single-admin lab context.
CC2: Communication and Information	CC2.1-CC2.3	Implemented	Multi-channel alerting (Discord, SMTP, TheHive, PagerDuty); MISP bi-directional IOC sharing; Shuffle notification routing

			by severity; PatchMon CVE correlation daily
CC3: Risk Assessment	CC3.1-CC3.4	Implemented	CVSS base/temporal/environmental scoring; weekly OpenVAS + monthly Nessus; MISP threat feeds; Wazuh FIM detects unauthorized configuration changes; Git change history
CC4: Monitoring of Controls	CC4.1-CC4.2	Implemented	Dual SIEM 100+ correlation rules <5min MTBD; Wazuh SCA CIS audits continuous; Uptime Kuma 50+ monitors 60s checks; TheHive tracks deficiencies with SLA enforcement
CC5: Control Activities	CC5.1-CC5.3	Implemented	7-layer defense-in-depth architecture; TLS 1.3 mandatory (Traefik), SSH passwords disabled globally, MFA 100% admin, default-deny all platforms; controls deployed as IaC via Ansible/Terraform
CC6: Logical and Physical Access	CC6.1-CC6.8	Implemented	Authentik SSO + Traefik ForwardAuth; Ed25519 SSH key-only; PA-VM User-ID; Step-CA PKI; Authentik 30-min idle timeout; SafeLine WAF + Suricata IPS external threat controls; TLS 1.3/WireGuard all transmission
CC7: System Operations	CC7.1-CC7.5	Implemented	Prometheus 15s scrape; Uptime Kuma 50+ monitors; Checkmk; Zeek NSM + ntopng; Wazuh SCA 92-98% CIS; Shuffle SOAR 15+ playbooks <30min MTTR; PBS backups with quarterly restore testing
CC8: Change Management	CC8.1	Implemented	Git commit required for all IaC changes; Terraform plan review; Ansible dry-run; WSUS approval workflow; snapshot-before-patch; container SHA-256 verification; branch protection + PR review
CC9: Risk Mitigation	CC9.1-CC9.2	Partial	CVSS-based remediation; network segmentation contains blast radius; Wazuh Active Response automated containment; MISP proactive IOC blocking. CC9.2 partial: no formal vendor contracts; SBOM (Trivy/Grype) planned Q2 2026.

Version History

Version	Date	Description
1.0	January 2026	Initial release covering six frameworks: NIST CSF 2.0, CIS Controls v8.1, ISO 27001:2022, NIST SP 800-53 Rev 5, CISA ZTMM v2.0, NIST SP 800-207.
1.1	January 2026	Corrected N/A controls and coverage percentages across framework summaries.
1.2	March 2026	Added Palo Alto PA-VM NGFW, NSM sensor (Zeek/ntopng), Cisco/VLAN enhancements. Updated PROTECT, DETECT, and Zero Trust pillar evidence.
2.0	April 2026	Added AICPA SOC 2 Trust Services Criteria (CC1-CC9). Integrated multi-cloud hybrid scope (AWS, Azure, GCP - 6 nodes). Updated all framework summaries. Consolidated executive overview.